Playbook de réponse : demande de paiement piégée

Livrable du track 1. Il répond aux quatre questions du guide : qui est alerté, quelles actions sont automatiques, lesquelles restent humaines, comment c'est documenté. La colonne « État » dit ce que le code fait au 11 octobre 2026, pas ce que la conception prévoit.

Légende : **fait** (code et tests dans le dépôt), **partiel** (une partie manque, dite sur la ligne), **humain** (geste d'une personne, outillé ou non), **non fait**.

Principes

- Aucune action automatique ne déplace de fonds. Les actions automatiques ne font que bloquer.
- L'alerte montre les faits bruts, jamais la justification rédigée par un agent.
- Une pause ne se lève que par une décision humaine.
- Sans réponse humaine dans le délai, une demande en attente est refusée. Un délai dépassé ne vaut jamais accord.
- L'outil prépare le dossier. Il ne classe pas l'incident et ne notifie aucune autorité.

Ce qui déclenche le playbook

Déclencheur	Source	État
Score du détecteur au seuil ou au-dessus	Porte d'entrée, `gateway/src/detector.ts`, seuil 70	Fait
Demande rejetée par le schéma	Porte d'entrée, `gateway/schemas/inbound.schema.json`	Fait
Rafale d'un même agent	Limite de débit, 5 demandes sur 10 s	Fait. Incident sans quarantaine : le contenu n'a pas été lu
Décision 0 du contrat, motif hostile	Événement `Decision`, lu dans l'indexeur par `response/src/relay-watch.ts`	Fait, sur anvil et sur le L1 de test
Trois refus bénins du même agent en 60 s	Même source	Fait

Motifs hostiles : facture ou placement inconnu, agent sans mandat, action inconnue. Ils ouvrent un incident dès la première fois. Motifs bénins : rejeu, facture déjà payée, placement trop élevé. Ils laissent une entrée de journal, puis ouvrent un incident au troisième (`specs/05-incident.md`, § 3 et § 4).

1. Qui est alerté

Rôle	Alerté quand	Ce qu'il reçoit	État
Analyste sécurité	À chaque incident de sécurité	Demande, agent, score, codes raison,	Partiel : alerte affichée sur la sortie du service et journalisée, avec ses

Rôle	Alerté quand	Ce qu'il reçoit	État
		motif du contrat	destinataires en rôles. Elle n'est envoyée à personne
Trésorier	À chaque incident de sécurité	Les mêmes faits bruts	Partiel, même réserve
Approbateur	Une demande dépasse le seuil d'approbation	La facture et le montant inscrits au contrat	Fait : ligne « en attente d'approbation » du dashboard, compte à rebours
Exploitation	Une demande reste 15 s en file, relais arrêté	Alerte de disponibilité	Fait, lue dans le journal
Responsable conformité	Un rapport d'incident est généré	Le rapport et l'empreinte du journal	Partiel : le rapport est servi sur `GET /incidents`, personne n'est notifié

L'alerte ne porte ni bénéficiaire ni montant exposé : le service de réponse ne lit pas les registres du contrat, et une facture inconnue n'en a pas.

2. Ce qui est automatique

#	Action	Par qui	Trace	Délai relevé	État
1	Détection : score, codes raison, horodatage	Porte d'entrée, ou contrat	`DETECTION`, `DECISION_OBSERVED`	Porte : 226 ms après l'arrivée. Contrat : 1,9 s	Fait
2	Quarantaine du document	Service de réponse	`QUARANTINED`	17 ms après la détection	Fait
3	Pause de l'agent d'origine	Service de réponse	`AGENT_PAUSED`	Porte : 24 ms. Contrat : 6,5 s après le bloc	Partiel : pause hors chaîne. La porte refuse l'agent, le relais écarte ses demandes. La pause sur la chaîne existe (`pauseAgent`), aucun service ne l'appelle
4	Alerte	Service de réponse	`ALERT_SENT`	Porte : 32 ms. Contrat : 6,5 s	Partiel : voir section 1

#	Action	Par qui	Trace	Délai relevé	État
				après le bloc	
5	Rapport d'incident prérempli depuis le journal	Service de réponse	`INCIDENT_REPORT_GENERATED`	40 ms après la détection	Fait. Le montant exposé reste vide
6	Refus d'une demande en attente à l'échéance	Contrat, `expire`	Événement `Decision`, motif `APPROVAL_TIMEOUT`	30 s dans la démo	Fait
7	Refus de tout émetteur non admis	Nœud du L1, liste d'émetteurs admis	Message d'erreur du nœud	Avant tout contrat	Fait, `docs-jury/preuves/scene-aws.md`

Délais relevés sur un incident par chemin, scènes 3 et 4 jouées sur le L1 de test. Le chemin du contrat inclut l'attente de l'indexeur.

3. Ce qui reste humain

#	Décision	Qui	Outil	État
1	Qualifier : attaque réelle ou faux positif	Analyste sécurité	Commande `human` de `response/`	Humain, outillé. L'auteur est déclaré, pas authentifié. La décision n'est pas signée
2	Lever la pause d'un agent	Analyste, puis propriétaire pour la reprise	Commande `human`, décision `AGENT_RESUMED`	Humain, outillé. La porte applique la levée
3	Révoquer le jeton d'un agent	Analyste	Commande `human`, décision `TOKEN_REVOKED`	Humain, outillé
4	Approuver ou refuser un paiement au-dessus du seuil	Approbateur	`approve` ou `refuse` du contrat	Humain, outillé. Clé de l'approbateur
5	Mettre un agent ou le coffre en pause sur la chaîne	Gardien	`pauseAgent`, `pauseVault` du contrat	Fonctions testées. Non branchées à l'outil : la décision `VAULT_PAUSED` est journalisée, l'appel reste manuel

#	Décision	Qui	Outil	État
6	Retirer une adresse de la liste d'émetteurs admis	Administrateur du L1	Précompilé du L1	Humain, sans outil dédié
7	Classer l'incident et décider d'une notification	Responsable conformité	Hors de l'outil	Humain
8	Retour d'expérience : le cas rejoint le jeu de mesure, le seuil est revu	Équipe sécurité	Nouvelle version du jeu	Humain, sans outil

Commandes, depuis `response/`, service lancé :

```
npm run human -- ATTACK_CONFIRMED --author <id> --incident <id> --agent <id>
```

```
npm run human -- AGENT_RESUMED --author <id> --agent <id>
```

Décisions admises : `FALSE_POSITIVE`, `ATTACK_CONFIRMED`, `AGENT_RESUMED`, `TOKEN_REVOKED`, `VAULT_PAUSED`, `VAULT_RESUMED`. Rôle par `--role` : `ANALYST` par défaut, `OWNER` ou `APPROVER`.

4. Comment c'est documenté

Le journal chaîné. Chaque étape écrit une entrée, liée à la précédente par son empreinte. Un script vérifie la chaîne et signale toute entrée modifiée, retirée ou déplacée.

```
npm run verify-journal -- var/journal.jsonl --expect-head <empreinte> --
expect-seq <rang>
```

Le rapport d'incident. Un par incident, régénéré après la qualification. Schéma : `specs/schemas/incident-report.schema.json`. Il contient :

- l'identifiant de l'incident et les horodatages d'arrivée, de détection, de pause et d'alerte ;
- l'agent d'origine et la chaîne d'autorité : mandat, client, signataire, empreinte de la demande, transaction ;
- le score, le seuil et les codes raison ;
- la décision du contrat, son motif, la transaction et le bloc ;
- le montant effectivement sorti ;
- les actions automatiques exécutées, chacune avec son rang au journal ;
- la décision humaine et son auteur ;
- l'empreinte de tête du journal au moment du rapport.

La chaîne. Les décisions du contrat se relisent dans les événements `Decision` et `Paid`, sans passer par nos services.

Réserves

- « Habilité » n'est pas vérifié : quiconque atteint le port local du journal peut consigner une décision humaine.
- Aucune authentification entre services : ils n'écoutent que sur la machine locale.
- Sans empreinte de tête gardée ailleurs, une troncature en fin de journal passe inaperçue.
- Le journal est « au moins une fois » : une entrée peut y figurer deux fois, jamais zéro.
- Le document mis en quarantaine est conservé en clair sur le disque du service.